A01 - Broken Access Control

- **Problem:** Users can access data or perform actions beyond their intended permissions
- **Impact:** Unauthorized data disclosure, modification, deletion, or privileged actions

Common vulnerabilities :

- **Least privilege violations:** Excessive permissions
- **Access control bypass:** Manipulating URLs or API requests
- **Insecure direct object reference (IDOR):** Accessing other users' resources by changing ID
- **Privilege escalation:** Gaining unauthorized admin access
- **Token manipulation:** Tampering with JWTs or cookies
- **Misconfiguration:** Missing API authorization or overly permissive CORS

Preventing Broken Access Control

- ◉ **The Frontend is not trusted:** data coming from the frontend cannot be trusted
- ✓ **The backend is the only trusted domain:** sensitive operations must be done on the backend
- ✓ **Deny by default:** Explicitly grant access only when authorized

- **Least privilege:** Grant users only the permissions they need
- **Server-side enforcement:** Never rely on client-side access controls
- **Check every request:** Validate authorization for every resource and operation
- **Secure sessions:** Protect tokens and properly invalidate sessions
- **Restrict CORS:** Allow only explicitly trusted origins
- **Test authorization:** Verify that users cannot access other users' resources or privileged functions